

# INCIDENT RESPONSE REPORT

## Lumma Stealer — DLL Side-Loading via ClickFix Phishing

|                |                                                               |
|----------------|---------------------------------------------------------------|
| Report Date    | June 07, 2026                                                 |
| Analyst        | Amr Khaled Elgendy                                            |
| Alert Rule     | SOC338 — Lumma Stealer DLL Side-Loading via ClickFix Phishing |
| Event ID       | 316                                                           |
| Severity       | CRITICAL                                                      |
| Classification | True Positive — Data Leakage                                  |
| Affected Host  | 172.16.17.216                                                 |
| Victim         | dylan@letsdefend.io                                           |

### 1. Executive Summary

A critical-severity phishing campaign was identified targeting an internal user via a spoofed Microsoft Windows 11 upgrade notification. The attacker leveraged a ClickFix-style phishing page to socially engineer the victim into executing an obfuscated PowerShell command, which subsequently invoked mshta.exe as a Living-Off-The-Land Binary (LOLBin) to download and execute the Lumma Stealer payload. The activity was confirmed as a True Positive. Immediate containment actions were taken to isolate the affected host and block malicious infrastructure.

### 2. Alert Details

|                      |                                                                  |
|----------------------|------------------------------------------------------------------|
| SMTP Source IP       | 132.232.40.201                                                   |
| Source Address       | update@windows-update.site                                       |
| Destination Address  | dylan@letsdefend.io                                              |
| Email Subject        | Upgrade your system to Windows 11 Pro for FREE                   |
| Malicious Domain     | windows-update.site                                              |
| Payload URL          | https://overcoatpassably.shop/Z8UZbPyVpGfdRS/maloy.mp4           |
| Payload SHA256       | 15c80b5be235bf2a8c38291eb697a702c07dde087eb459e9ea46a2bee17c5f03 |
| VirusTotal Detection | 17/56 vendors — Trojan.PowerShell.LummaStealer                   |

### 3. Attack Timeline

| #  | Stage                    | Description                                                                                                                               |
|----|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|
| T1 | Phishing Email Received  | Victim received a spoofed email from update@windows-update.site impersonating a Microsoft Windows 11 upgrade notification.                |
| T2 | Malicious Link Clicked   | Victim visited https://windows-update.site/ — a fake Microsoft update page using ClickFix social engineering to prompt command execution. |
| T3 | PowerShell Execution     | Obfuscated PowerShell command executed: used string replacement (-replace) to hide mshta.exe invocation and evade detection.              |
| T4 | LOLBin Abuse (mshta.exe) | powershell.exe spawned mshta.exe as child process to fetch                                                                                |

|           |                  |                                                                                                                      |
|-----------|------------------|----------------------------------------------------------------------------------------------------------------------|
|           |                  | and execute the remote payload from overcoatpassably.shop.                                                           |
| <b>T5</b> | Payload Delivery | maloy.mp4 (Lumma Stealer) downloaded and executed on the endpoint — confirmed malicious by 17/56 VirusTotal vendors. |
| <b>T6</b> | Containment      | Endpoint isolated, malicious domains blocked, suspicious processes terminated.                                       |

## 4. Attack Chain Analysis

The attack followed a multi-stage infection chain:

- **Phishing Email:** Spoofed sender (update@windows-update.site) sent an email with subject 'Upgrade your system to Windows 11 Pro for FREE', directing the victim to a malicious domain.
- **ClickFix Social Engineering:** The landing page at windows-update.site impersonated a legitimate Microsoft update portal and instructed the user to run a command — a known ClickFix technique.
- **PowerShell Obfuscation:** Command used string replacement to hide mshta.exe execution: powershell -Command ('ms]]]]ht]]]]a]]]].]]]]exe ...' -replace ']]')
- **LOLBin Execution (mshta.exe):** mshta.exe was spawned as a child of powershell.exe to fetch and execute the remote .mp4 payload — a common LOLBin abuse technique to bypass application whitelisting.
- **Lumma Stealer Execution:** Payload identified as Lumma Stealer — an infostealer targeting browser credentials, cookies, and authentication tokens.

## 5. MITRE ATT&CK Mapping

| Technique ID     | Technique Name                       | Observed Activity                                                              |
|------------------|--------------------------------------|--------------------------------------------------------------------------------|
| <b>T1566.002</b> | Phishing: Spearphishing Link         | Malicious link in email directing victim to fake Microsoft update page         |
| <b>T1204.002</b> | User Execution: Malicious File       | Victim tricked into running PowerShell command via ClickFix social engineering |
| <b>T1027</b>     | Obfuscated Files or Information      | PowerShell used string replacement (-replace) to obfuscate mshta.exe execution |
| <b>T1218.005</b> | Signed Binary Proxy Execution: Mshta | mshta.exe used as LOLBin to execute remote HTA payload                         |
| <b>T1059.001</b> | Command and Scripting: PowerShell    | PowerShell used to deliver and execute the payload                             |
| <b>T1105</b>     | Ingress Tool Transfer                | Lumma Stealer payload downloaded from remote C2 URL                            |
| <b>T1555</b>     | Credentials from Password Stores     | Lumma Stealer targets browser-stored credentials and cookies                   |

## 6. Indicators of Compromise (IOCs)

| Type       | Value               | Context          |
|------------|---------------------|------------------|
| IP Address | 132.232.40.201      | SMTP source / C2 |
| Domain     | windows-update.site | Phishing         |

|        |                                                                  |                            |
|--------|------------------------------------------------------------------|----------------------------|
|        |                                                                  | landing page               |
| Domain | overcoatpassably.shop                                            | Payload delivery C2        |
| URL    | https://windows-update.site/                                     | Fake Microsoft update page |
| URL    | https://overcoatpassably.shop/Z8UZbPyVpGfdRS/maloy.mp4           | Lumma Stealer payload      |
| SHA256 | 15c80b5be235bf2a8c38291eb697a702c07dde087eb459e9ea46a2bee17c5f03 | maloy.mp4 — Lumma Stealer  |
| Email  | update@windows-update.site                                       | Phishing sender            |
| Host   | 172.16.17.216                                                    | Affected endpoint          |

## 7. Containment Actions

- Isolated affected endpoint (172.16.17.216) from the network to prevent further C2 communication.
- Blocked malicious domains: windows-update.site and overcoatpassably.shop at the perimeter firewall.
- Blocked source IP 132.232.40.201 at the email gateway.
- Terminated suspicious processes: powershell.exe and mshta.exe on the affected host.
- Initiated full AV and EDR scan on the infected endpoint.
- Reset credentials for dylan@letsdefend.io — Lumma Stealer targets browser-stored passwords, cookies, and tokens.
- Reviewed and revoked active browser sessions associated with the compromised account.

## 8. Recommendations

- **Email Filtering:** Implement rules to block emails from lookalike domains impersonating Microsoft (e.g., \*windows-update.site).
- **mshta.exe Restriction:** Disable or restrict mshta.exe execution via AppLocker or Windows Defender Application Control if not required in the environment.
- **PowerShell Logging:** Enable Script Block Logging and Command Line Auditing for all endpoints (Event IDs 4103, 4104).
- **User Awareness Training:** Educate users on ClickFix phishing techniques, fake CAPTCHA prompts, and unsolicited system upgrade pages.
- **EDR Tuning:** Create detection rules for powershell.exe → mshta.exe parent-child process relationships.
- **Threat Intelligence:** Add identified IOCs to threat intelligence platform and update blocklists across all security controls.

## 9. Final Classification

**TRUE POSITIVE — Lumma Stealer Infection via ClickFix Phishing and LOLBin Abuse**